

|                                                                                   |                                                                                                                                               |                                                                                                                                                  |
|-----------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <b>POLITIKE I PROCEDURE</b>                                                                                                                   |                                                                                                                                                  |
|                                                                                   | Datum usvajanja:                                                                                                                              | 1 / 2                                                                                                                                            |
|                                                                                   | V1: 01-01-2025                                                                                                                                |                                                                                                                                                  |
|                                                                                   | <b>PROCEDURA UPRAVLJANJA<br/>RANJIVOSTIMA IT SISTEMA</b>                                                                                      |                                                                                                                                                  |
|                                                                                   | AKAZ Standard 1.15 (2020)<br>Kriterij: 1.15.3; 5.2.30                                                                                         |                                                                                                                                                  |
|                                                                                   | Odobreno od:                                                                                                                                  |                                                                                                                                                  |
|                                                                                   | <br>Medicinski direktor<br>Doc. dr. Azur Tulumović, dr. med. | <br>Direktor ASA Bolnice<br>Prof. dr. Mustafa Hiroš, dr. med. |

## 1. OPĆA IZJAVA

**1.1.** Procedura opisuje proces upravljanja ranjivostima koji ASA Bolnica primjenjuje s ciljem pravovremenog otkrivanja, klasifikacije, prioritetnog rješavanja i nadzora sigurnosnih ranjivosti u IT okruženju. Upravljanje ranjivostima predstavlja ključni segment informacijske sigurnosti i podržava cjelokupnu zaštitu bolničkog IT sustava, infrastrukture, podataka i poslovnih procesa.

## 2. PODRUČJE PRIMJENE

- 2.1.** Procedura se primjenjuje na sve IT resurse u vlasništvu bolnice, uključujući:
- 2.1.1. Serverske i mrežne sisteme
  - 2.1.2. Radne stanice i prijenosne uređaje
  - 2.1.3. Operativne sisteme, aplikacije i baze podataka
  - 2.1.4. Softverske i hardverske komponente izložene vanjskim ili unutarnjim prijetnjama

## 3. DISTRIBUCIJA I NADZOR

- 3.1.** Dokument se distribuira IT odjelu, vanjskim sigurnosnim partnerima (po potrebi) i nadzornim tijelima.
- 3.2.** Za provedbu i ažuriranje ove procedure zadužen je **Voditelj IT odjela**.
- 3.3.** Saradnja s eksternim partnerima u slučaju specijaliziranih skeniranja, revizija ili penetration testova je definirana ugovorom ili SLA-om.

## 4. PROCEDURA

### 4.1. Inventarizacija imovine

- 4.1.1. Svi IT resursi (hardver i softver) se vode u ažurnoj inventar listi s podacima o vlasništvu, odgovornoj osobi, kritičnosti i životnom ciklusu.
- 4.1.2. Inventar se pregledava i revidira najmanje jednom godišnje ili prilikom značajnih promjena.

### 4.2. Identifikacija ranjivosti (vulnerability scanning)

- 4.2.1. Redovno se provodi automatsko i ručno skeniranje IT okruženja radi identifikacije poznatih ranjivosti.
- 4.2.2. Skeniranja vrši IT odjel putem internog alata ili u saradnji s vanjskim sigurnosnim partnerima.
- 4.2.3. Zakazana su mjesečna skeniranja serverskog okruženja i kvartalna skeniranja radnih stanica.

### 4.3. Klasifikacija ranjivosti

- 4.3.1. Ranjivosti se klasificiraju po CVSS (Common Vulnerability Scoring System) skali:

4.3.1.1. Visok rizik

4.3.1.2. Srednji rizik

4.3.1.3. Nizak rizik

4.3.2. Svaka identificirana ranjivost se procjenjuje prema utjecaju na:

4.3.2.1. Povjerljivost, integritet i dostupnost podataka

4.3.2.2. Regulatorne obaveze (npr. GDPR)

4.3.2.3. Potencijalni poslovni prekid

#### 4.4. Remedijacija i zakrpe (patching)

4.4.1. Zakrpe (patches) se provode prema utvrđenom rasporedu:

4.4.1.1. Kritične ranjivosti: unutar 2 dana

4.4.1.2. Srednje: unutar 30 dana

4.4.1.3. Niske: u skladu s planom redovnog održavanja

4.4.2. Automatski update-i su omogućeni gdje je moguće, a za kritične sisteme se koristi testno okruženje prije primjene zakrpa.

#### 4.5. Praćenje i izvještavanje

4.5.1. Nakon svake provedene remedijacije, ponovno se provodi skeniranje kako bi se potvrdilo zatvaranje ranjivosti.

4.5.2. Mjesečni izvještaji o ranjivostima i poduzetim akcijama se šalju IT menadžmentu.

4.5.3. Dokumentacija o ranjivostima i akcijama čuva se najmanje 12 mjeseci.

#### 4.6. Eksterni testovi i auditi

4.6.1. Periodično se angažiraju vanjski partneri za penetration testove i sigurnosne revizije (najmanje jednom godišnje).

4.6.2. Rezultati eksternih testova se uspoređuju s internim analizama i integriraju u plan sigurnosnih poboljšanja.

### 5. REVIZIJA

5.1. Ova procedura se revidira jednom u tri godine ili ranije u slučaju:

5.1.1. Implementacije novih alata ili sistema

5.1.2. Uvođenja novih regulatornih zahtjeva

5.1.3. Identifikacije značajnih sigurnosnih incidenata

Prilagodili:

Stručni saradnik za kvalitet

Amar Smajić



Menadžer informacionih  
tehnologija

Enes Hatibović

